DATA ITEM DESCRIPTION

Title: CYBERSECURITY SUPPLY CHAIN RISK MANAGEMENT (C-SCRM) SOFTWARE BILL OF MATERIAL (SBOM) REQUIREMENTS

Number: DI-SESS-82433
AMSC Number: N10452
DTIC Applicable: N/A
Preparing Activity: AS
Applicable Forms: N/A

Approval Date: 20240119
Limitation: N/A
GIDEP Applicable: N/A
Project Number: SESS-2024-002

Use/relationship: Data delivered using this Data Item Description (DID) specifies the requirements for a Software Bill of Materials (SBOM) that includes comprehensive software component information and upstream relationship assertions in alignment with CISA and NTIA guidelines. The SBOM will ensure suppliers/vendors maintain and/or improve Cybersecurity Supply Chain Risk Management (C-SCRM) activities. This approach provides a consistent and repeatable approach for sharing product component data.

a. SBOM Types. Vendors should specify the type of SBOM provided based on the software development stage. Possible types include Design, Source, Build, Analyzed, Deployed, and Runtime SBOMs.

b. Each software component entry must include information about its upstream relationships.

c. The word “item” is used throughout the document to refer to software components of the system.

d. This DID contains the format, content, and intended use information for the data product resulting from the work task described in the solicitation.

e. This DID should be tailored in the Contract Data Requirements List (CDRL) to include only the required specific data elements from Table 1. Examples of specific uses for the data and the data elements that could be used for each purpose follows:

(1) Software Bill of Materials (SBOM) data can be used to establish the details and supply chain relationships of various components used in building in a system. The SBOM will provide managers essential information that enables the identification, forecasting, mitigation, and management of software security. The data will be used to form a foundational data layer on which further security tools, practices, and assurances can be built.

Requirements:

1. Reference Documents. The applicable issue of the documents cited herein, including their approval dates and dates of any applicable amendments, notices, and revisions, shall be as specified in the contract.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

1.1 References:

a. The Minimum Elements For a Software Bill of Materials (SBOM), https://www.ntia.doc.gov/files/ntia/publications/sbom_minimum_elements_report.pdf

b. Types of Software Bill of Materials (SBOM), https://www.cisa.gov/resources-tools/resources/types-software-bill-materials-sbom

c. Framing Software Component Transparency: Establishing a Common Software Bill of Materials (SBOM), https://www.ntia.gov/files/ntia/publications/ntia_sbom_framing_2nd_edition_20211021.pdf

d. Minimum Requirements for Vulnerability Exploitability eXchange (VEX), https://www.cyclonedx.org/specification/overview/

2. Format. The C-SCRM SBOM shall be submitted in English and machine-readable format to ensure interoperability and automation support.

3. Content. Include a complete inventory of all first party and third party components in the SBOM. The data shall contain the information specified by the contract as referenced by the Data Items in Table 1. The data shall meet the requirements as specified in the Description column of Table 1. All fields designated by the contract shall be included. Fields for which data is not available shall be left blank. The data shall be included to the lowest indenture level (component level) for all items, including subcontractor items. Adhere to NTIA guidance on documenting upstream relationships, ensuring transparency and clarity in the software supply chain as referenced in Example 1.

3.1. Vulnerability-Exploitability eXchange (VEX) Information. In addition to SBOM data, vendors are encouraged to provide VEX information for each software component listed in the SBOM, where such information is available and applicable.

3.1.1. The VEX should include, for each vulnerability, a status (e.g., Not affected, Affected, Fixed, Under Investigation) and any recommended actions or remediation to address the vulnerability.

3.1.2. VEX information should be regularly updated to reflect the status of vulnerabilities, especially after significant software updates or when new vulnerabilities are discovered.

3.1.3. Vendors should ensure that VEX data is synchronized with the corresponding SBOM data.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

TABLE 1 Data Items

Data Item	Description
SBOM Metadata	
Product Name	Name of the top-level product
Product Version	Specific version of the top-level product
Product Vendor Name	Name of the vendor or manufacturer of the product.
Product Identifier	Unique identifier for the top-level product (PURL, CPE, etc)
Product Hash	Cryptographic hash of the top-level product; must be clear how hash was generated
SBOM Type	Specifies the category of the SBOM based on the stage of software development and deployment.
Version	Schema version of the SBOM document
Timestamp	Date and time when the SBOM was created or last updated
Author	Person or entity responsible for creating or compiling the SBOM
CAGE Code	Identifies the specific entity within the DoD supply chain
External References	Links to additional information, documentation, or resources related to the product or its components.
Tools	Information about the tools or software used to create or compile the SBOM
Component Details	
Component Name	Component name
Component Version	Component version
Supplier Name	Component supplier or creator
Component Type	Category of the component (e.g., framework, library, container, platform, OS, device, firmware, etc.)
Component Use	Description of component use within product.
Unique Identifier	Specific identifier for the component (PURL, CPE, UUID, etc)
Component License	Software licenses associated with the component
Component Hashes	Cryptographic hash of component
Hashing Function	Specify the function used to generate the hashes, which is necessary for validation

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

External References	Links to additional information about the component (download location, version control system URL)
Dependencies	
Dependencies	Component dependencies (name, version, scope, and relationship)
Relationship	Information about component relationship
Vulnerabilities	
Vulnerabilities	List the known vulnerabilities associated with each component. Include references to CVEs or other identifiers
Exploitability Status	For each listed vulnerability, provide its current exploitability status (Not Affected, Affected, Fixed, Under Investigation)
Remediation Information	Detail the recommended actions or steps for addressing each listed vulnerability
VEX Information	Include detailed VEX information for each component, where available.
Extensions	
Extension Name	Name of the extension
Schema Version	Schema version of the extension
Extension Elements	Data related to the extension (attributes, relationships, vulnerability data)

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.

Example 1 Conceptual SBOM table with upstream relationship assertions

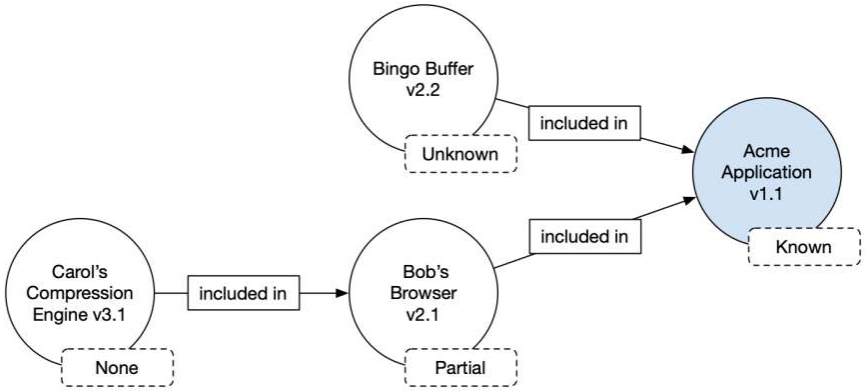


Figure 2: Conceptual SBOM graph with upstream relationship assertions

Component Name	Supplier Name	Version String	Author	Hash	UID	Relationship	Relationship Assertion
Application	Acme	1.1	Acme	0x123	234	Primary	Known
|--- Browser	Bob	2.1	Bob	0x223	334	Included in	Partial
|--- Compression Engine	Carol	3.1	Acme	0x323	434	Included in	None
|--- Buffer	Bingo	2.2	Acme	0x423	534	Included in	Unknown

End of DI-SESS-82433

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:03Z
Check the source to verify that this is the current version before use.